

La double authentification

ou authentification à deux facteurs

Plan

1. Contexte

2. De quoi on parle ?

2.1. L'authentification

2.2. La double authentification

3. Choix de la technologie

3.1. Les différentes possibilités

3.2. La solution retenue

4. Exemple d'implémentation

1. Contexte

Une application web dont l'authentification se faisait par mot de passe.

Auparavant hébergée à l'IRAP et accessible uniquement par le réseau interne, elle va être déployée au CROcc (Cloud Recherche Occitanie) et ouverte vers l'extérieur.

→ Cette évolution augmente l'exposition aux risques de sécurité.

Comme l'application permet notamment la suppression de données, nous avons jugé bon d'en renforcer les conditions d'authentification en mettant en œuvre un système de double authentification.

2.1. L'authentification

L'authentification est le processus qui permet de vérifier l'identité d'un utilisateur ou d'un système avant de lui donner accès à une ressource.

Autrement dit : **L'authentification sert à prouver que l'on est bien la personne que l'on prétend être.**

Elle repose sur trois grandes catégories de preuves :

- **Ce que l'on sait** (mot de passe, code pin, question secrète...)
- **Ce que l'on possède** (téléphone, ordinateur, clef de sécurité...)
- **Ce que l'on est** (reconnaissance facile, lecteur d'empreintes digitales...)

2.2. La double authentification

L'authentification repose sur 3 type de facteurs : connaissance, possession et biométrie.

La double authentification repose sur la combinaison de deux facteurs distincts.

Exemple correct :

Mot de passe et code reçu sur le téléphone (connaissance et possession).

Exemple incorrect :

Mot de passe et question secrète (connaissance et connaissance).

3.1. Les solutions

Méthodes	Avantages	Contraintes	Niveau de sécurité
Notifications push	Bonne expérience utilisateur	- Pas facile à déployer - Dépendant d'internet	Élevé
SMS / Emails	- Facile à déployer - Accessible à tous	- Code à recopier - Surface d'attaque élevée (boite mail compromise, phishing, interception...) - Dépendant d'internet	Moyen
TOTP	- Facile à déployer - Standard répandu - Fonctionne hors ligne	- Code à recopier - Vulnérable au phishing	Bon
Clé physique	Surface d'attaque faible	- Coût matériel - Risque de perte	Très élevé

3.2. La solution retenue

Le TOTP (Time-based One-Time Password).

Activation :

- Le serveur génère une clef secrète, l'enregistre, puis la fourni à votre application d'authentification.

Utilisation :

- Un code à 6 chiffres, mis à jour toutes les 30 secondes est calculé automatiquement à partir de cette clef et de l'heure actuelle.
- On rentre le code sur l'application à laquelle on essaye d'accéder.
- Le serveur effectue le même calcul et compare son code à 6 chiffres avec celui que vous lui avez fourni.

4. Exemple d'implémentation

Mais d'abord, avez-vous des questions ?